



File No.: EXP202307807

RESOLUTION OF SANCTIONING PROCEDURE

From the procedure instructed by the Spanish Agency for Data Protection and based on the following

FACTS

FIRST: A.A.A. (hereinafter, the complainant) filed a complaint with the Spanish Agency for Data Protection on April 27, 2023. The complaint is directed against the VICEPRESIDENCY, DEPARTMENT OF EDUCATION AND UNIVERSITIES OF THE COMMUNITY OF MADRID with NIF S7800001E. The reasons for the complaint are as follows:

The complainant registered in the scholarship application process for students with disabilities and shortly thereafter received an email with the opening deadlines of the platform, filtering the email addresses of all scholarship applicants in the "To" field instead of placing them in BCC.

The email is attached to the complaint.

SECOND: In accordance with Article 65.4 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and Guarantee of Digital Rights (hereinafter LOPDGDD), the complaint was forwarded to the Department of Education and Universities of the Community of Madrid for analysis and to inform this Agency within one month of the actions taken to comply with the requirements set forth in data protection regulations.

The transfer, which was carried out in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), was acknowledged on June 9, 2023, as evidenced by the acknowledgment of receipt in the file.

On June 22, 2023, this Agency received a written response indicating that, "The email referred to by the complainant was sent as a reminder solely to ensure that our applicants did not miss the opportunity to benefit from this scholarship and that, due to human error and exceptionally, it was sent to multiple applicants without using the blind carbon copy (BCC) functionality. Furthermore, it should be noted that, although the email is a protected personal data, no other personal data has been exposed to third parties as a result of the aforementioned sending."

THIRD: On July 5, 2023, in accordance with Article 65 of the LOPDGDD, the complaint filed by the complainant was admitted for processing.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

FOURTH: On October 18, 2023, the Director of the Spanish Agency for Data Protection agreed to initiate sanctioning proceedings against the respondent for the alleged infringement of Article 5.1.f) of the GDPR and Article 32 of the GDPR, classified under Article 83.4 of the GDPR and Article 83.5 of the GDPR. This initiation agreement was duly notified on October 23, 2023, as evidenced by the acknowledgment of receipt in the file.

FIFTH: On November 6, 2024, allegations were received against the initiation agreement, which, in summary, stated the following:

- The Department asserts that the data controller of that agency, complying with the obligations set forth by the General Data Protection Regulation, conducted the appropriate risk analysis of personal data processing in January 2023, implementing the necessary measures resulting from that analysis.
- Secondly, the Department maintains that, being aware of the legal obligations that condition the management of personal data of third parties, it has followed all instructions and recommendations derived from this management, processing more than 6,000 applications each year, without a single complaint of this type arising from it.
- Another allegation made by the responsible agency is that, in order to eliminate the specific security breach that occurred in this year's call, it has implemented the sending of automatic emails through the

scholarship management software of the Community of Madrid and not through emails from Outlook, as had been done until now.

SIXTH: On February 13, 2024, a resolution proposal was made in which all the allegations raised were addressed and a declaration of infringement for non-compliance with Articles 5.1.f) and 32 of the GDPR was proposed. The proposal was duly notified on February 14, 2024, as evidenced by the acknowledgment of receipt in the file.

Regarding the response to the allegations presented against the initiation agreement, the Agency stated in the resolution proposal:

- The fact that the risk analysis of personal data processing was conducted in January 2023 did not prevent the dissemination of email addresses to third parties without adopting the measures required by the regulations on personal data protection that would ensure their confidentiality.
- It is not appropriate to accept as a mitigating factor or as a circumstance that diminishes the severity the fact that the Department has followed all instructions and recommendations derived from the management of personal data, processing more than 6,000 applications each year; rather, the opposite is true, as precisely...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

3/10

Due to the high number of treatments it performs and because it affects personal data related to physical condition, the entity being claimed is obliged to act with the special diligence that must be required of an organization of these characteristics, which carries out numerous treatments of personal data on a massive scale, including special categories of data.

-

Regarding the allegation about the implementation of automatic email sending through the management tool for scholarships of the Community of Madrid and not through emails from Outlook, as had been done until now, it is noted that although this Agency positively values the adoption of new measures that result in greater security concerning the processing of personal data and that may prevent, in the future, incidents like the one at issue in this procedure, security measures must be adopted with regard to each and every risk present in the processing of personal data, including the human factor.

The proven facts in the procedure evidence the disclosure of email addresses when an email was sent to the claimant without a blind copy, breaching technical and organizational measures and violating the confidentiality of the data.

Consequently, the Agency considered that the allegations should be dismissed, indicating that the arguments presented do not undermine the essential content of the infringement declared to have been committed nor do they constitute sufficient justification or exculpation.

SEVENTH: On 26/02/2024, this Agency received a written statement of allegations regarding the proposed resolution in which, in summary, it reiterates what was stated in the written allegations of 6/11/2023:

-

The Ministry states that it adopted the appropriate measures to eliminate the security breach mentioned in the initiation agreement of the sanctioning procedure.

-

Since 8/11/2023, they have implemented the sending of automatic emails through the management tool for scholarships of the Community of Madrid and not through emails from Outlook, as they had been doing.

In view of all that has been acted upon, the Spanish Agency for Data Protection considers the following facts to be proven,

PROVEN FACTS

FIRST: The claimant registered for the "disability scholarships 2022-2023" call of the General

Directorate of Universities and Artistic Education of the Community of Madrid.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

4/10

SECOND: On April 27, they received an email reminding them that "on April 12, the Call for Aid for Students with Disabilities pursuing university studies or higher artistic education for the 2022-2023 academic year was published."

THIRD: This email was sent to all applicants for said scholarship without the "blind copy" functionality, exposing the email addresses to all recipients.

LEGAL GROUNDS

I

Competence

In accordance with the powers granted to each supervisory authority by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47, 48.1, 64.2, and 68.1 of the LOPDGDD, the Director of the Spanish Agency for Data Protection is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states that: "The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued in its development, and, as long as they do not contradict them, subsidiarily by the general rules on administrative procedures."

II

Allegations to the Proposed Resolution

On 26/02/2024, a written statement of allegations was received from the Ministry of Education, Science, and Universities, General Directorate of Universities, in which, in summary, it reiterates what was stated in the written allegations to the initiation agreement and states that:

-

That agency adopted the appropriate measures to eliminate the security breach mentioned in the initiation agreement of the sanctioning procedure.

-

Since 8/11/2023, they have implemented the sending of automatic emails through the management tool for scholarships of the Community of Madrid and not through emails from Outlook, as they had been doing.

Therefore, the Agency considers that the allegations should be dismissed, reiterating that the arguments presented do not undermine the essential content of the infringement declared to have been committed nor do they constitute sufficient justification or exculpation.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

5/10

III

Preliminary Issues

In the present case, according to the provisions of Article 4.1 of the GDPR, there is evidence of the processing of personal data, given that the Ministry of Education and Universities of the Community of Madrid utilizes personal data, such as the email addresses of individuals who can access the disability scholarship call for 2022-2023.

The Ministry of Education and Universities of the Community of Madrid carries out this activity in its capacity as the data controller, as it is the entity that determines the purposes and means of such activity, pursuant to Article 4.7 of the GDPR.

Article 4, paragraph 12 of the GDPR broadly defines "personal data security breaches" (hereinafter

security breach) as “all breaches of security that result in the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or unauthorized communication or access to such data.”

In this case, there is a personal data security breach under the circumstances mentioned above, categorized as a confidentiality breach, resulting from the sending of an email without a blind copy, making the corresponding email addresses accessible.

IV

Article 5.1.f) of the GDPR

Article 5.1.f) “Principles relating to processing” of the GDPR states:

“1. Personal data shall be:

f) processed in a manner that ensures appropriate security of the personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, using appropriate technical or organizational measures (‘integrity and confidentiality’).”

In this case, it is noted that the personal data of the recipients of the email that prompted the complaint, contained in the database of the Ministry of Education and Universities of the Community of Madrid, were improperly exposed to third parties by sending an email without a blind copy, making their respective email addresses accessible to all recipients.

In accordance with the evidence available at this moment in the resolution of the sanctioning procedure, it is considered that the Ministry of Education and Universities of the Community of Madrid has processed personal data of the complainant, specifically the email address, without adopting the appropriate technical and organizational measures required by data protection regulations that would ensure the confidentiality of the data, and therefore this fact is considered to constitute an infringement for violation of Article 5.1.f) of the GDPR.

V

Classification of the infringement of Article 5.1.f) of the GDPR

Article 83.5.a) of the GDPR classifies as an administrative infringement any violation of “the basic principles for processing, including the conditions for consent in accordance with Articles 5, 6, 7, and 9.”

In this regard, the LOPDGDD, in its Article 71 “Infringements” establishes that:

“Infringements are constituted by the acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law.”

For the purposes of the statute of limitations, Article 72 “Very serious infringements” of the LOPDGDD indicates:

“1. Based on what is established in Article 83.5 of Regulation (EU) 2016/679, the following are considered very serious and shall be subject to a three-year statute of limitations: infringements that constitute a substantial violation of the articles mentioned therein and, in particular, the following:

a) The processing of personal data in violation of the principles and guarantees established in Article 5 of Regulation (EU) 2016/679. (...)”

VI

Article 32 of the GDPR

Article 32 “Security of processing” of the GDPR states:

“1. Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying likelihood and severity for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which shall include, among others:

a) the pseudonymization and encryption of personal data;

b) the ability to ensure the confidentiality, integrity, availability, and permanent resilience of processing systems and services;

c) the ability to restore the availability and access to personal data quickly in the event of a physical or technical incident;

d) a process for regularly verifying, assessing, and evaluating the effectiveness of technical and organizational measures to ensure the security of processing.

2. In assessing the appropriateness of the level of security, particular consideration shall be given to...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

7/10

assesses the risks presented by data processing, particularly as a consequence of the destruction, loss, or accidental or unlawful alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data.

3. Adherence to a code of conduct approved under Article 40 or to a certification mechanism approved under Article 42 may serve as an element to demonstrate compliance with the requirements established in paragraph 1 of this article.

4. The data controller and the data processor shall take measures to ensure that any person acting under the authority of the controller or the processor and having access to personal data may only process such data in accordance with the instructions of the controller, unless required to do so by Union or Member State law.

Despite the fact that the Ministry of Education and Universities of the Community of Madrid had conducted a risk analysis, an adequate level of security commensurate with the risk that would ensure the confidentiality, integrity, and availability of the processing services was not guaranteed, especially when special categories of data were being processed.

In accordance with the evidence available at this time of the resolution of the sanctioning procedure, it is considered that the known facts constitute an infringement attributable to the Ministry of Education and Universities of the Community of Madrid for violation of Article 32 of the GDPR.

VII

Classification of the infringement of Article 32 of the GDPR

Article 83.4.a) of the GDPR classifies as an administrative infringement any violation of "the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43."

In this regard, the LOPDGDD, in its Article 71 "Infringements," establishes that "Acts and conduct referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those contrary to this organic law, constitute infringements."

For the purposes of the statute of limitations, Article 73 "Infringements considered serious" of the LOPDGDD indicates:

"Based on what is established in Article 83.4 of Regulation (EU) 2016/679, the following are considered serious and shall be subject to a two-year statute of limitations: infringements that constitute a substantial violation of the articles mentioned therein and, in particular, the following:

f) The failure to adopt those technical and organizational measures that are appropriate to ensure a level of security adequate to the risk of processing,

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

8/10

in the terms required by Article 32.1 of Regulation (EU) 2016/679." (...)

VIII

Sanction for the infringements of Articles 5.1.f) and 32 of the GDPR

Article 83 "General conditions for the imposition of administrative fines" of the GDPR, paragraph 7, establishes:

"Without prejudice to the corrective powers of the supervisory authorities under Article 58, paragraph 2, each Member State may establish rules on whether and to what extent administrative fines may be imposed on authorities and public bodies established in that Member State."

Likewise, Article 77 "Applicable regime for certain categories of controllers or processors" of the LOPDGDD provides as follows:

1. The regime established in this article shall apply to the processing for which they are responsible or for which they are processors:

(...)

c) The General Administration of the State, the administrations of the autonomous communities, and the entities that comprise the Local Administration.

2. When the controllers or processors listed in paragraph 1 commit any of the infringements referred to in Articles 72 to 74 of this organic law, the competent data protection authority shall issue a resolution declaring the infringement and establishing, where appropriate, the measures that should be taken to cease the conduct or correct the effects of the infringement that has been committed, except for that provided for in Article 58.2.i of Regulation (EU) 2016/679 of the European Parliament and of the Council of April 27, 2016.

The resolution shall be notified to the controller or processor, to the body to which it hierarchically depends, where applicable, and to the affected parties who had the status of interested parties, where applicable.

3. Without prejudice to the provisions of the previous paragraph, the data protection authority shall also propose the initiation of disciplinary proceedings when there are sufficient indications for it. In this case, the procedure and the sanctions to be applied shall be those established in the legislation on disciplinary or sanctioning regimes that are applicable.

Likewise, when the infringements are attributable to authorities and executives, and it is proven that there are technical reports or recommendations for processing that have not been duly addressed, the resolution imposing the sanction shall include a reprimand naming the responsible position and shall order publication in the Official State Gazette or the corresponding regional gazette.

4. The resolutions regarding the measures and actions referred to in the previous paragraphs shall be communicated to the data protection authority.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

9/10

5. The actions taken and the resolutions issued under this article will be communicated to the Ombudsman or, where applicable, to the analogous institutions of the autonomous communities.

6. When the competent authority is the Spanish Agency for Data Protection, it will publish on its website, with due separation, the resolutions related to the entities mentioned in paragraph 1 of this article, with an express indication of the identity of the data controller or processor who committed the infringement. When the competence corresponds to an autonomous data protection authority, the publicity of these resolutions will be governed by its specific regulations.

This provision excludes the imposition of administrative fines when the infringements referred to in articles 72 to 74 of the LOPDGDD are committed by the categories of data controllers or processors listed in paragraph 1 of the aforementioned article 77, establishing that the procedures arising from violations of personal data protection regulations committed by those entities will be resolved by declaring the infringements.

IX

Adoption of measures

The text of the resolution establishes what the infringements committed were and the facts that led to the violation of data protection regulations, from which it is clearly inferred what measures are to be adopted, without prejudice to the fact that the type of procedures, mechanisms, or specific instruments for implementing them corresponds to the sanctioned party, as it is the data controller who fully knows its organization and must decide, based on proactive responsibility and a risk-based approach, how to comply with the GDPR and the LOPDGDD.

The party summoned in its response dated 26/02/2024 has indicated that as of 8/11/2023, the measure whereby the sending of automatic emails is carried out through the Community of Madrid's scholarship management software and not through emails from Outlook, as they had been doing, has been fully implemented, which guarantees that the necessary actions have been taken to eliminate

possible security breaches like the one that prompted the initiation of this file.

Therefore, in accordance with the applicable legislation and having assessed the criteria for the graduation of the sanctions whose existence has been established, the Director of the Spanish Agency for Data Protection

RESOLVES:

FIRST: TO DECLARE that the VICEPRESIDENCY, DEPARTMENT OF EDUCATION AND UNIVERSITIES, with NIF S7800001E, has infringed the provisions of article 5.1.f) of the GDPR and article 32 of the GDPR, an infringement classified in article 83.4 of the GDPR and article 83.5 of the GDPR.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

10/10

SECOND: TO NOTIFY this resolution to the VICEPRESIDENCY, DEPARTMENT OF EDUCATION AND UNIVERSITIES.

THIRD: TO COMMUNICATE this resolution to the Ombudsman, in accordance with the provisions of article 77.5 of the LOPDGDD.

In accordance with the provisions of article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative procedure in accordance with art. 48.6 of the LOPDGDD, and in accordance with the provisions of article 123 of the LPACAP, the interested parties may optionally file a motion for reconsideration before the Director of the Spanish Agency for Data Protection within one month from the day following the notification of this resolution or directly file an administrative contentious appeal before the Administrative Litigation Chamber of the National Court, in accordance with the provisions of article 25 and paragraph 5 of the fourth additional provision of Law 29/1998, of July 13, regulating the Administrative Litigation Jurisdiction, within two months from the day following the notification of this act, as provided in article 46.1 of the aforementioned Law.

Finally, it is noted that in accordance with the provisions of art. 90.3 a) of the LPACAP, the firm resolution in the administrative procedure may be provisionally suspended if the interested party expresses their intention to file an administrative contentious appeal. If this is the case, the interested party must formally communicate this fact by writing to the Spanish Agency for Data Protection, submitting it through the Electronic Registry of the Agency

[<https://sedeagpd.gob.es/sede-electronica-web/>], or through any of the other registries provided for in art. 16.4 of the aforementioned Law 39/2015, of October 1. They must also provide the Agency with documentation that proves the effective filing of the administrative contentious appeal. If the Agency does not become aware of the filing of the administrative contentious appeal within two months from the day following the notification of this resolution, it will consider the provisional suspension concluded.

938-16012024

Mar España Martí

Director of the Spanish Agency for Data Protection

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es